Logo UANL

PENDIENTE: agregar archivo assets/logos/uanl.png

Logo de la facultad

PENDIENTE: agregar archivo assets/logos/facultad.png

Universidad Autónoma de Nuevo León

Facultad: pendiente

Casino Royale Enterprises.

PRODUCTO INTEGRADOR DE APRENDIZAJE (PIA)

Plan de Administración de Riesgos de TI

Caso académico: Casino Royale Enterprises

Materia	Administración de Riesgos de TI
Grupo	061
Docente	Melissa Jacqueline Mendieta Gonzalez
Fecha	04/11/2026

Integrantes del equipo	Matrícula
David Emiliano Rangel Tovar	**Matrícula pendiente**
Fernando Garza Chavez	**Matrícula pendiente**
Kevin Daniel Grimaldo Esquivel	1997415
Alejandro Martinez Moya	**Matrícula pendiente**
Rene Villareal Torres	**Matrícula pendiente**

Casino Royale Enterprises es una empresa ficticia creada para este trabajo académico. Su misión, visión, sistemas y datos son supuestos del caso.

Índice

1. Descripción de la empresa y del área de TI 3
- 1.1 Datos generales 3
- 1.2 Misión y visión de la empresa 3
- 1.3 Misión y visión del área de TI 3
- 1.4 Productos y servicios 3
- 1.5 Valores 4
- 1.6 Área de TI: estructura, sistemas y tecnologías 4

2. Introducción 5
- 2.1 Objetivo del plan 5
- 2.2 Alcance 5
- 2.3 Responsables de la gestión de riesgos 5
- 2.4 KPI y KRI 6

3. Metodología 7
- 3.1 Estándar: ISO 31000:2018 7
- 3.2 Herramientas de identificación y análisis 7
- 3.3 Clasificación de riesgos 8
- 3.4 Criterios de valoración 8
- 3.5 Implementación de ISO 31000 en el casino (caso simulado) 9

4. Análisis de riesgos 12
- 4.1 Resumen de riesgos 12
- 4.2 Estrategias de tratamiento 13
- 4.3 Ficha de cada riesgo y plan de respuesta 13

5. Mapa de calor 20
- 5.1 Lectura del mapa 20

6. Monitoreo y control 21
- 6.1 Objetivos 21
- 6.2 Qué se monitorea 21
- 6.3 Herramientas y técnicas de monitoreo 21
- 6.4 Tablero de KPI y KRI por riesgo 21
- 6.5 Frecuencia de monitoreo por nivel de riesgo 23
- 6.6 Documentación y reporte 24
- 6.7 Beneficios del monitoreo y control 24

7. Comunicación 25
- 7.1 Qué se comunica 25
- 7.2 Quién comunica y quién recibe 25
- 7.3 Canales de comunicación 26
- 7.4 Frecuencia de comunicación 26

8. Conclusión 27

Referencias 28

1. Descripción de la empresa y del área de TI

Caso académico ficticio. Los datos de esta sección son supuestos elaborados por el equipo para desarrollar el plan; no describen a una empresa real.

1.1 Datos generales

Nombre	Casino Royale Enterprises
Giro	Entretenimiento: centro de juegos con apuesta (casino) con mesas de juego, máquinas tragamonedas y servicios de hospitalidad. Para el caso se supone que opera con permiso de la Secretaría de Gobernación, conforme a la Ley Federal de Juegos y Sorteos y su Reglamento (Cámara de Diputados del H. Congreso de la Unión, 1947; Secretaría de Gobernación, 2004).
Clientes y mercado objetivo	Adultos mayores de 18 años de la zona metropolitana, turistas y viajeros de negocios, y jugadores frecuentes y VIP inscritos en el programa de lealtad.
Ubicación y cobertura	Una sala principal en Monterrey, Nuevo León (supuesto del caso), con cobertura local y regional y operación los 365 días del año en horario extendido.

1.2 Misión y visión de la empresa

MISIÓN

Ofrecer una experiencia de entretenimiento segura, justa y responsable, con servicio de excelencia y apego a la ley.

VISIÓN

Ser en 2030 el casino de referencia del noreste de México por la confianza de sus clientes, la integridad de sus juegos y la seguridad de su operación.

1.3 Misión y visión del área de TI

MISIÓN DE TI

Garantizar la disponibilidad, integridad y confidencialidad de la información y de los sistemas que sostienen el juego, la caja y la atención a clientes.

VISIÓN DE TI

Ser un área de TI que habilite la operación continua del casino con sistemas resilientes, seguros y gestionados con base en riesgos.

1.4 Productos y servicios

- Mesas de juego: blackjack, ruleta, póker y dados.
- Máquinas tragamonedas electrónicas conectadas a un sistema central.
- Programa de lealtad con puntos, promociones y área VIP.
- Caja: venta y cambio de fichas y pago de premios.
- Restaurante-bar y eventos de entretenimiento.

1.5 Valores

Integridad
Juegos justos y transparentes.

Legalidad
Cumplimiento de permisos y leyes aplicables.

Juego responsable
Cuidado del cliente y de su bienestar.

Seguridad
Protección de personas, dinero e información.

Servicio
Atención cordial y eficiente.

Trabajo en equipo
Colaboración entre áreas.

1.6 Área de TI: estructura, sistemas y tecnologías

El área de TI depende de la Dirección General y está integrada por: Director de TI, Jefe de Seguridad de la Información (CISO), Jefe de Infraestructura y Redes, Jefe de Desarrollo y Aplicaciones, Jefe de Soporte Técnico, Jefe de Tecnología de Juego (tragamonedas). El área de Vigilancia (CCTV) depende de Seguridad, pero usa la infraestructura que administra TI.

Servidores	Clúster de servidores virtualizados en el centro de datos de la sala; servidor de video para CCTV; servicio en la nube para correo y respaldos.
Aplicaciones	Sistema de gestión de casino y de tragamonedas; sistema de caja; gestión de clientes y lealtad (CRM); punto de venta; software de gestión de video; ERP de contabilidad y nómina; módulo de prevención de lavado (PLD).
Bases de datos	Bases de datos relacionales de clientes y lealtad, transacciones de caja, contabilidad del juego y bitácoras de seguridad.
Redes	Red cableada con switches administrables y VLAN para juego, caja, CCTV y oficinas; Wi-Fi para clientes separado; firewall perimetral; VPN para soporte remoto; un enlace de internet principal.
Seguridad	Directorio Activo, antivirus, firewall de aplicaciones web para el portal de clientes y monitoreo de eventos de seguridad (SIEM).
Equipos de usuario	Computadoras de caja y oficinas, estaciones de vigilancia, terminales punto de venta y tabletas para supervisores.

2. Introducción

2.1 Objetivo del plan

Identificar, analizar, valorar y tratar los riesgos de TI de Casino Royale Enterprises y los riesgos operativos que dependen de la tecnología, para proteger los ingresos del juego, la información de los clientes, el cumplimiento legal y la continuidad de la operación. El plan define quién es responsable de cada riesgo, qué se hará, con qué recursos y en qué plazo, y cómo se medirá el avance.

2.2 Alcance

El plan cubre al área de TI y a los procesos de negocio de la sala principal que dependen de ella:

- Juego en mesas y en máquinas tragamonedas.
- Caja, pagos con tarjeta y pago de premios.
- Videovigilancia (CCTV).
- Programa de lealtad y datos de clientes.
- Cumplimiento en prevención de lavado de dinero (PLD), conforme a la Ley Federal para la Prevención e Identificación de Operaciones con Recursos de Procedencia Ilícita, LFPIORPI (Cámara de Diputados del H. Congreso de la Unión, 2025b), y en protección de datos personales, conforme a la Ley Federal de Protección de Datos Personales en Posesión de los Particulares, LFPDPPP (Cámara de Diputados del H. Congreso de la Unión, 2025a).

Quedan fuera los riesgos de construcción, protección civil y los del restaurante-bar que no involucran sistemas. El plan aplica de noviembre de 2026 a octubre de 2027 y se renueva cada año.

2.3 Responsables de la gestión de riesgos

Dirección General	Patrocina el plan, aprueba la política de riesgos y el presupuesto.
Comité de Riesgos	Director General, Director de TI, Director de Finanzas, Gerente de Operaciones de Juego, Gerente de Riesgos y Cumplimiento y Oficial de Cumplimiento PLD. Prioriza, aprueba tratamientos y da seguimiento mensual.
Gerente de Riesgos y Cumplimiento	Líder del plan. Coordina al equipo de gestión de riesgos, mantiene la matriz y el tablero, y consolida reportes.
Director de TI	Responsable de la infraestructura y los sistemas; integra los riesgos de TI al presupuesto.
Dueños de riesgo	Ejecutan los planes de respuesta y reportan KPI y KRI de su riesgo (ver tabla de análisis).
Auditoría Interna	Revisa de forma independiente que los controles funcionen.
Todo el personal	Reporta incidentes y situaciones de riesgo por los canales definidos.

2.4 KPI y KRI

Un **KPI** (indicador clave de desempeño) mide qué tan bien funciona un control. Un **KRI** (indicador clave de riesgo) mide qué tan expuesta está la empresa. Leídos juntos permiten saber si un control realmente reduce el riesgo y actuar antes de que el problema crezca. Cada uno de los 12 riesgos tiene su control, KPI, KRI, interpretación y acción en el tablero de la sección 6.4. Además, el plan completo se mide con estos indicadores:

KPI del programa	Meta
% de planes de respuesta ejecutados en el tiempo comprometido	≥ 90 %
% de riesgos revisados en la frecuencia que marca su nivel	100 %
% de personal capacitado en riesgos y seguridad en el año	≥ 95 %

KRI del programa	Meta
# de riesgos en nivel Crítico o Alto	Bajar de 6 a 3 en 12 meses
# de incidentes de seguridad relevantes por trimestre	Tendencia a la baja
# de observaciones de autoridades o auditoría	0

3. Metodología

3.1 Estándar: ISO 31000:2018

El estándar principal es **ISO 31000:2018, Gestión del riesgo — Directrices** (International Organization for Standardization [ISO], 2018). Se eligió porque sirve para cualquier tipo de organización y de riesgo, por lo que permite tratar en una sola matriz los riesgos tecnológicos y los de la operación de juego, la caja y el cumplimiento legal. ISO 31000 es una guía y no se certifica: su valor está en dar un lenguaje y un método comunes.

El estándar tiene tres partes que se aplicaron en el casino:

PRINCIPIOS

La gestión del riesgo debe ser integrada, estructurada y exhaustiva, adaptada, inclusiva y dinámica; usar la mejor información disponible; considerar factores humanos y culturales, y mejorar continuamente.

MARCO DE REFERENCIA

Liderazgo y compromiso de la dirección, integración, diseño, implementación, valoración y mejora del sistema de gestión de riesgos.

PROCESO

Comunicación y consulta; alcance, contexto y criterios; evaluación del riesgo (identificar, analizar y valorar); tratamiento; seguimiento y revisión; registro e informe.

Para escoger las técnicas de identificación y análisis se tomó como apoyo la norma IEC 31010:2019, que describe técnicas como la lluvia de ideas, las entrevistas y las encuestas (International Electrotechnical Commission [IEC], 2019).

3.2 Herramientas de identificación y análisis

Encuestas	Cuestionario anónimo de 10 preguntas al personal de caja, mesas, vigilancia, TI y administración sobre fallas, malas prácticas y situaciones de riesgo que han visto. Ayudó a detectar R5, R12 y el uso de cuentas compartidas (R9).
Entrevistas	Entrevistas de 45 minutos con los responsables de TI, seguridad de la información, caja, operaciones de juego, vigilancia y cumplimiento PLD para conocer controles actuales, incidentes previos y dependencias entre sistemas.
Lluvia de ideas	Dos talleres con el Comité de Riesgos para proponer riesgos sin juzgarlos, agruparlos por categoría y acordar su probabilidad e impacto. De ahí surgieron R7, R8, R10 y R11.
Análisis FODA	Revisión de fortalezas y debilidades internas del área de TI y de oportunidades y amenazas externas, para relacionar cada debilidad con una amenaza y obtener riesgos concretos.

FORTALEZAS

- Equipo de TI interno que conoce la operación.
- Sistemas centrales con soporte del fabricante.
- Vigilancia con personal dedicado en todos los turnos.
- Dirección comprometida con el plan.

DEBILIDADES

- Cámaras y equipos con muchos años de uso.
- Cuentas de administrador compartidas.
- Respaldos sin pruebas de restauración.
- Un solo enlace de internet para pagos.

OPORTUNIDADES

- Servicios en la nube para respaldos y recuperación.
- Herramientas de seguridad accesibles (doble factor, EDR).
- Leyes de PLD y datos personales que impulsan buenas prácticas.
- Capacitación ofrecida por proveedores.

AMENAZAS

- Ransomware y correos engañosos (phishing).
- Fraude organizado en mesas y tragamonedas.
- Uso del casino para lavado de dinero.
- Fallas de proveedores de pagos y comunicaciones.

3.3 Clasificación de riesgos

Categoría	Qué incluye	Riesgos
Financiero	Pérdidas directas de dinero o de flujo de efectivo.	R2, R8
Operativo	Fallas en procesos, personas o equipos de la operación de juego.	R1, R5
Tecnológico	Fallas o ataques a sistemas, redes y datos.	R3, R4, R7, R9, R11, R12
Legal	Incumplimiento de leyes, permisos o regulaciones.	R6
Reputacional	Pérdida de confianza de clientes, autoridades o la sociedad.	R10

3.4 Criterios de valoración

Probabilidad	
Alta	Se espera que ocurra varias veces al año o la vulnerabilidad ya es conocida y fácil de aprovechar.
Media	Puede ocurrir alrededor de una vez al año; hay antecedentes o condiciones que lo facilitan.
Baja	Poco probable; requiere condiciones especiales o se espera menos de una vez cada dos o tres años.

Impacto	
Alto	Detiene el juego o la caja por varias horas, causa pérdidas importantes, sanciones de la autoridad o daño a la reputación.
Medio	Afecta un área o sistema por algunas horas, genera pérdidas moderadas o quejas de clientes.
Bajo	Efecto local que se resuelve dentro del turno con recursos propios.

El nivel de riesgo se obtiene combinando probabilidad e impacto con la siguiente regla:

Probabilidad \ Impacto	Bajo	Medio	Alto
Alta	Moderado	Alto	Crítico
Media	Bajo	Moderado	Alto
Baja	Bajo	Bajo	Moderado

Los seis riesgos de la matriz anterior (10 de octubre de 2026) estaban en una escala de 5x5. Para el PIA se convirtieron a la escala 3x3 así:

Probabilidad 5x5	Escala PIA
Casi seguro / Muy probable	Alta
Posible	Media
Poco probable / Raro	Baja

Impacto 5x5	Escala PIA
Catastrófico / Mayor	Alto
Moderado	Medio
Menor / Insignificante	Bajo

Con la conversión, R2 pasó de Medio a Moderado, R3 de Alto a Moderado y R5 de Medio a Moderado. R1 y R6 se mantienen en Alto y R4 en Bajo.

3.5 Implementación de ISO 31000 en el casino (caso simulado)

Qué se busca con el estándar. Que todas las áreas usen los mismos criterios para medir riesgos, que las inversiones en seguridad se decidan por prioridad y no por urgencia, y que los riesgos se revisen como parte de las decisiones del negocio y no solo cuando ocurre un incidente.

Quién está a cargo. La Dirección General patrocina el proyecto y el Gerente de Riesgos y Cumplimiento lo lidera, con el apoyo del Director de TI y del Comité de Riesgos.

Duración. La implementación se llevó en seis fases durante 24 semanas (mayo a octubre de 2026), más una actividad de comunicación y consulta que acompañó todo el proyecto.

#	Fase	Qué se hizo	Responsable	Tiempo
1	**Mandato y compromiso** ISO 31000: Liderazgo y compromiso (5.2)	La Dirección General aprueba la política de riesgos, nombra al líder del plan y crea el Comité de Riesgos.	Dirección General	Sem 1–2
2	**Diseño del marco** ISO 31000: Marco de referencia (5.4)	Se definen roles, criterios de riesgo, escalas 3x3, plantilla de matriz y calendario de revisión.	Gerente de Riesgos y Cumplimiento con el Director de TI	Sem 3–6
3	**Alcance, contexto y criterios** ISO 31000: Proceso (6.3)	Inventario de activos de TI y procesos críticos, análisis FODA y requisitos legales.	Director de TI y Oficial de Cumplimiento PLD	Sem 5–8
4	**Evaluación del riesgo** ISO 31000: Proceso (6.4)	Encuestas, entrevistas y lluvia de ideas para identificar, analizar y valorar los 12 riesgos; matriz y mapa de calor.	Equipo de gestión de riesgos con los dueños de riesgo	Sem 8–14

#	Fase	Qué se hizo	Responsable	Tiempo
5	**Tratamiento del riesgo** ISO 31000: Proceso (6.5)	Se elige estrategia por riesgo, se redactan planes de respuesta y el Comité aprueba presupuesto.	Dueños de riesgo; aprobación del Comité de Riesgos	Sem 14–20
6	**Seguimiento, registro e informe** ISO 31000: Proceso (6.6 y 6.7)	Arranca el tablero de KPI y KRI, se entrega el primer informe al Comité y se programa la revisión.	Gerente de Riesgos y Cumplimiento; Auditoría Interna	Sem 20–24
—	**Comunicación y consulta** ISO 31000: Proceso (6.2)	Se informa y consulta a cada área durante todas las fases.	Gerente de Riesgos y Cumplimiento	Sem 1–24

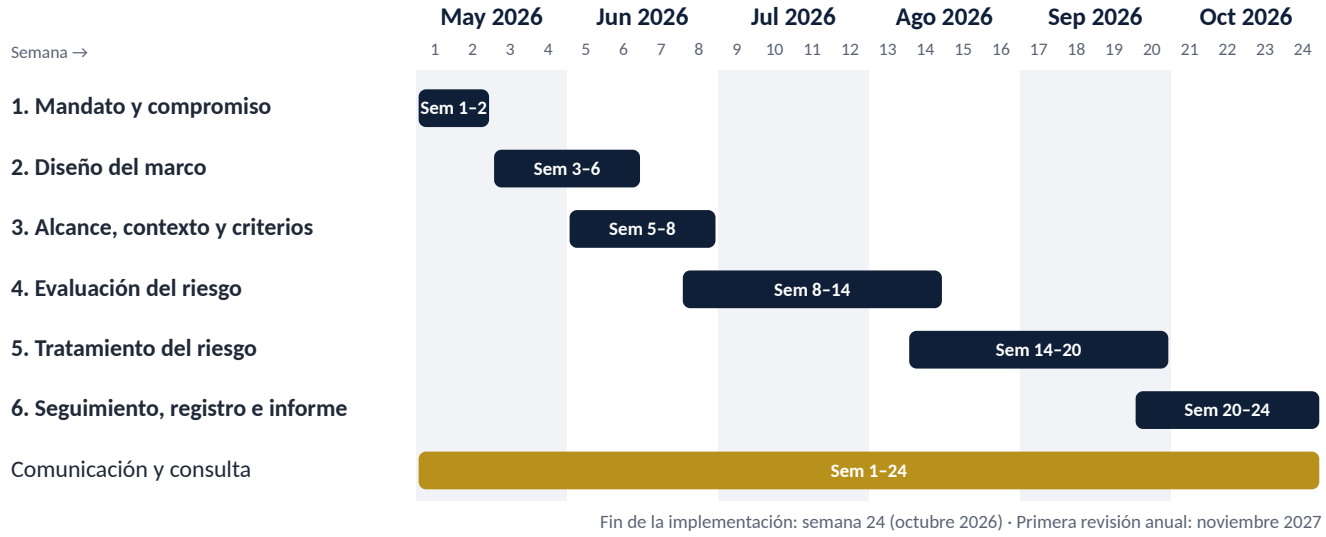


Figura 1. Línea del tiempo de la implementación de ISO 31000 (caso simulado).

Problemas y retos que se enfrentaron.

Reto	Qué pasó	Cómo se resolvió
Resistencia del personal	Cajeros y crupieres veían las entrevistas como una auditoría para buscar culpables.	Se explicó que el fin es prevenir, se usaron encuestas anónimas y se compartieron los resultados.
Operación de horario extendido	Los turnos rotativos impedían reunir a todos en talleres largos.	Sesiones de 30 minutos en cada turno y encuesta en línea.
Datos incompletos	No existía una bitácora de incidentes; muchos eventos solo se recordaban de palabra.	Se reconstruyó la historia con tickets de soporte y reportes de vigilancia, y se creó un registro único de incidentes.
Áreas separadas	TI, operaciones de juego y cumplimiento tenían listas de riesgos distintas.	Un solo Comité de Riesgos y una sola matriz con dueño por riesgo.
Sistemas heredados	Tragamonedas y cámaras antiguas no aceptan todas las actualizaciones.	Controles compensatorios (red aislada, alertas) y plan de reemplazo por etapas.

Reto	Qué pasó	Cómo se resolvió
Presupuesto limitado	No era posible atender todos los riesgos al mismo tiempo.	El mapa de calor se usó para priorizar: primero lo Crítico y Alto.
Escalas diferentes	La matriz anterior usaba 5x5 y el PIA pide 3x3.	Se definió una tabla de conversión y se documentaron los cambios de nivel.

Cada cuándo se renueva.

- Matriz de riesgos y mapa de calor: cada trimestre.
- KPI y KRI: según el nivel del riesgo (sección 6.5).
- Política, marco y criterios de riesgo: cada año, en noviembre.
- Revisión extraordinaria ante un incidente grave, un sistema o proveedor crítico nuevo, un cambio de ley o de permisos, o un cambio en la distribución de la sala.
- ISO 31000 está en proceso de revisión; cuando se publique la nueva edición, el Comité evaluará la transición.

4. Análisis de riesgos

Se identificaron 12 riesgos: los seis de la matriz de riesgos del 10 de octubre de 2026 (R1 a R6) y seis riesgos propios de TI (R7 a R12). Cada uno se describe por el activo afectado, la amenaza y la vulnerabilidad que la amenaza aprovecha.

4.1 Resumen de riesgos

ID	Riesgo	Fuente	Categoría	Prob.	Impacto	Nivel	Estrategia	Responsable
R1	Manipulación de elementos de juego	Externa	Operativo	Media	Alto	Alto	Mitigar	Gerente de Operaciones de Juego
R2	Colusión empleado-cliente	Interna	Financiero	Baja	Alto	Moderado	Mitigar	Gerente de Caja y Tesorería
R3	Intervención en tragamonedas con dispositivos especializados	Externa	Tecnológico	Baja	Alto	Moderado	Mitigar	Jefe de Tecnología de Juego
R4	Ataque al sistema central de gestión de clientes	Externa	Tecnológico	Baja	Medio	Bajo	Aceptar	Jefe de Desarrollo y Aplicaciones
R5	Punto ciego o falla temporal en la vigilancia de la sala principal	Interna	Operativo	Alta	Bajo	Moderado	Mitigar	Jefe de Vigilancia (CCTV)
R6	Uso del casino para operaciones con recursos ilícitos	Externa	Legal	Media	Alto	Alto	Mitigar	Oficial de Cumplimiento PLD
R7	Ataque de ransomware	Externa	Tecnológico	Alta	Alto	Crítico	Mitigar	Jefe de Seguridad de la Información (CISO)
R8	Caída del sistema de pagos	Externa	Financiero	Media	Medio	Moderado	Transferir	Director de TI
R9	Acceso privilegiado indebido	Interna	Tecnológico	Media	Alto	Alto	Mitigar	Jefe de Seguridad de la Información (CISO)
R10	Fuga de datos de clientes	Externa	Reputacional	Media	Alto	Alto	Mitigar	Oficial de Privacidad
R11	Falla de respaldos	Interna	Tecnológico	Alta	Medio	Alto	Mitigar	Jefe de Infraestructura y Redes
R12	Uso de software no autorizado y memorias USB	Interna	Tecnológico	Media	Medio	Moderado	Evitar	Jefe de Soporte Técnico

4.2 Estrategias de tratamiento

Estrategia	Significado	Riesgos
Evitar	Eliminar la actividad o condición que origina el riesgo.	R12
Mitigar	Reducir la probabilidad, el impacto o ambos con controles.	R1, R2, R3, R5, R6, R7, R9, R10, R11
Transferir	Compartir el efecto económico con un tercero (contrato, seguro).	R8
Aceptar	Asumir el riesgo de forma consciente y vigilarlo, porque un control extra cuesta más de lo que reduce.	R4

4.3 Ficha de cada riesgo y plan de respuesta

R1 Manipulación de elementos de juego — Alto

Activo afectado	Barajas, dados, fichas y ruletas de las mesas de juego.		
Amenaza	Jugadores o terceros que marcan cartas, introducen dados cargados o alteran la ruleta.		
Vulnerabilidad	Inspección manual sin registro y sin trazabilidad por lote de los elementos de juego.		
Fuente	Externa	**Categoría**	Operativo
Probabilidad / Impacto	Media / Alto	**Nivel**	**Alto**
Justificación	El control actual depende del criterio de cada crupier y no deja registro, por lo que una alteración puede pasar varios turnos sin detectarse (Media). Cada mesa manipulada genera pagos indebidos, disputas con clientes y observaciones de la autoridad (Alto).		
Estrategia	**Mitigar**		
Plan de respuesta	1. Protocolo de inspección por turno con bitácora digital y firma del supervisor de mesa. 2. Cambio de barajas en cada turno y de dados cada 8 horas, con destrucción documentada. 3. Inventario de elementos de juego por lote con sello de seguridad. 4. Revisión por video de manos ganadoras fuera de patrón.		
Responsable	Gerente de Operaciones de Juego	**Tiempos**	Protocolo en 30 días; inventario por lote en 60 días; revisión mensual.
Recursos	Supervisores de mesa, lámparas UV y calibradores de dados, bitácora digital, sellos de seguridad.		

R2 Colusión empleado-cliente — Moderado

Activo afectado	Efectivo de caja, fichas y registros de pago de premios.		
Amenaza	Cajero que se pone de acuerdo con un cliente para pagos o cambios de fichas indebidos.		
Vulnerabilidad	El mismo cajero atiende por periodos largos a los mismos clientes y no hay alertas automáticas sobre patrones de pago.		
Fuente	Interna	**Categoría**	Financiero
Probabilidad / Impacto	Baja / Alto	**Nivel**	**Moderado**
Justificación	Requiere el acuerdo de dos personas y hay arqueos diarios (Baja). Si ocurre, la pérdida puede repetirse durante semanas y daña la confianza en la caja (Alto).		
Estrategia	**Mitigar**		
Plan de respuesta	1. Rotación obligatoria de cajeros entre ventanillas y turnos con calendario semanal. 2. Reglas de alerta en el sistema de caja: pagos repetidos del mismo cajero al mismo cliente y cambios de fichas sin juego registrado. 3. Arqueos sorpresa y doble firma en pagos mayores al límite que defina Tesorería. 4. Línea de denuncia anónima para el personal.		
Responsable	Gerente de Caja y Tesorería	**Tiempos**	Rotación en 15 días; alertas en 60 días; arqueos sorpresa mensuales.
Recursos	Calendario de rotación, módulo de reglas del sistema de caja, apoyo de Auditoría Interna.		

R3 Intervención en tragamonedas con dispositivos especializados — Moderado

Activo afectado	Máquinas tragamonedas y su red de comunicación con el sistema de gestión de tragamonedas.		
Amenaza	Personas externas que usan dispositivos electrónicos para alterar sensores, provocar fallas o generar créditos y premios falsos.		
Vulnerabilidad	Modelos con firmware desactualizado, gabinetes sin sensor de apertura conectado a alarma y red de máquinas sin monitoreo de anomalías.		
Fuente	Externa	**Categoría**	Tecnológico
Probabilidad / Impacto	Baja / Alto	**Nivel**	**Moderado**
Justificación	Requiere conocimiento y equipo especializado (Baja). Puede afectar varias máquinas a la vez, generar pérdidas y poner en duda la integridad del juego (Alto). En la matriz 5x5 era Alto; con la escala 3x3 queda en Moderado.		
Estrategia	**Mitigar**		
Plan de respuesta	1. Actualizar firmware según los boletines del fabricante. 2. Sellos y sensores de apertura de gabinete conectados a las alarmas de vigilancia. 3. Red de tragamonedas aislada y con alertas por créditos o pagos fuera de patrón. 4. Inspección técnica mensual de las máquinas.		
Responsable	Jefe de Tecnología de Juego	**Tiempos**	Firmware en 90 días; sensores en 120 días; inspección mensual.
Recursos	Técnicos de tragamonedas, soporte del fabricante, sensores de apertura, reglas en el sistema de gestión.		

R4 Ataque al sistema central de gestión de clientes — Bajo

Activo afectado	Sistema de gestión de clientes y lealtad (CRM) y su base de datos.		
Amenaza	Atacante externo que aprovecha fallas del portal web o contraseñas robadas para alterar puntos, saldos o datos.		
Vulnerabilidad	Portal de clientes expuesto a internet y parches que a veces se aplican con retraso.		
Fuente	Externa	**Categoría**	Tecnológico
Probabilidad / Impacto	Baja / Medio	**Nivel**	**Bajo**
Justificación	El sistema ya tiene firewall de aplicaciones web y doble factor para administradores (Baja). Un ataque afectaría puntos y promociones, pero no detendría el juego ni la caja (Medio).		
Estrategia	**Aceptar**		
Plan de respuesta	1. Mantener los controles actuales: firewall de aplicaciones web, parches mensuales y escaneo trimestral de vulnerabilidades. 2. Vigilar las alertas del sistema de monitoreo de seguridad (SIEM). 3. Plan de contingencia: congelar canjes de puntos y restaurar desde respaldo si hay alteración. 4. Reevaluar el riesgo cada trimestre o si cambia el sistema.		
Responsable	Jefe de Desarrollo y Aplicaciones	**Tiempos**	Revisión trimestral; contingencia activable en 1 hora.
Recursos	Herramientas actuales (firewall de aplicaciones, SIEM, escáner); sin inversión adicional.		

R5 Punto ciego o falla temporal en la vigilancia de la sala principal — Moderado

Activo afectado	Sistema de videovigilancia: cámaras, grabadores y software de gestión de video.		
Amenaza	Fallas de cámaras, pérdida de señal o mantenimiento que dejan zonas sin grabación.		
Vulnerabilidad	Cámaras con muchos años de uso, cobertura no revisada después de mover mesas y sin alertas automáticas de pérdida de señal.		
Fuente	Interna	**Categoría**	Operativo
Probabilidad / Impacto	Alta / Bajo	**Nivel**	**Moderado**
Justificación	Las fallas breves y los huecos de cobertura se presentan con frecuencia (Alta). Una falla aislada tiene efecto limitado porque hay personal en piso y otras cámaras (Bajo), aunque facilita R1 y R2.		
Estrategia	**Mitigar**		
Plan de respuesta	1. Mantenimiento preventivo mensual y reemplazo programado de las cámaras más antiguas. 2. Alertas automáticas de pérdida de señal en el software de video. 3. Revisión de cobertura cada vez que cambie la distribución de la sala. 4. Vigilancia física temporal mientras se repara una falla.		
Responsable	Jefe de Vigilancia (CCTV)	**Tiempos**	Alertas en 30 días; reemplazo escalonado en 6 meses; mantenimiento mensual.
Recursos	Técnico de CCTV, cámaras de reemplazo, licencia de alertas, guardias de piso.		

R6 Uso del casino para operaciones con recursos ilícitos

Alto

Activo afectado	Procesos de caja, compra y venta de fichas, pago de premios y expedientes de clientes.		
Amenaza	Clientes que ingresan efectivo de origen ilícito y lo retiran como premio para aparentar que es legal.		
Vulnerabilidad	Identificación incompleta de clientes en operaciones en efectivo y revisión manual de las operaciones que deben reportarse.		
Fuente	Externa	**Categoría**	Legal
Probabilidad / Impacto	Media / Alto	**Nivel**	**Alto**
Justificación	Los juegos con apuesta son actividad vulnerable según la LFPIORPI (art. 17, fracc. I) y el efectivo es el medio de pago principal (Media). Un incumplimiento puede traer multas, observaciones de la autoridad y daño a la reputación (Alto).		
Estrategia	**Mitigar**		
Plan de respuesta	1. Expediente de identificación del cliente obligatorio a partir de los umbrales que marca la ley. 2. Módulo de prevención de lavado (PLD) que acumule operaciones por cliente y genere alertas. 3. Presentar los avisos ante la autoridad en tiempo y forma. 4. Capacitación anual en PLD para cajeros y anfitriones; auditoría independiente anual.		
Responsable	Oficial de Cumplimiento PLD	**Tiempos**	Expedientes y alertas en 90 días; avisos según plazos legales; capacitación anual.
Recursos	Módulo PLD del sistema de caja, analista de cumplimiento, asesoría legal externa.		

R7 Ataque de ransomware

Crítico

Activo afectado	Servidores, bases de datos y equipos de usuario (caja, sistema de gestión de casino y ERP).		
Amenaza	Grupos criminales que cifran la información y piden rescate; suelen entrar por correos engañosos (phishing) o accesos remotos.		
Vulnerabilidad	Equipos con sistema operativo sin soporte, acceso remoto sin doble factor, poca capacitación contra phishing y red poco segmentada.		
Fuente	Externa	**Categoría**	Tecnológico
Probabilidad / Impacto	Alta / Alto	**Nivel**	**Crítico**
Justificación	En las entrevistas, TI reportó intentos de phishing frecuentes y equipos sin parches (Alta). Un cifrado detendría la caja, las tragamonedas en red y el programa de lealtad, con pérdidas por cada hora sin operar (Alto).		
Estrategia	**Mitigar**		
Plan de respuesta	1. Antimalware avanzado (EDR) en todos los servidores y equipos. 2. Doble factor de autenticación en VPN, correo y cuentas de administrador. 3. Parches críticos en máximo 15 días y retiro de equipos sin soporte. 4. Segmentar la red: juego, caja, CCTV y oficinas. 5. Simulacros de phishing trimestrales y ejercicio semestral del plan de respuesta a incidentes.		
Responsable	Jefe de Seguridad de la Información (CISO)	**Tiempos**	Doble factor y EDR en 30 días; segmentación en 90 días; simulacros trimestrales.
Recursos	Licencias EDR y de doble factor, equipo de TI, proveedor externo de respuesta a incidentes, presupuesto para renovar equipos.		

R8 Caída del sistema de pagos — Moderado

Activo afectado	Terminales punto de venta, sistema de caja y enlace con el procesador de pagos.		
Amenaza	Falla del procesador de pagos, del enlace de comunicaciones o del servidor de caja.		
Vulnerabilidad	Un solo enlace de internet para pagos y contrato con el procesador sin niveles de servicio ni penalizaciones.		
Fuente	Externa	**Categoría**	Financiero
Probabilidad / Impacto	Media / Medio	**Nivel**	**Moderado**
Justificación	El enlace ha fallado algunas veces al año (Media). La operación sigue en efectivo, pero se pierden ventas con tarjeta y se retrasan pagos (Medio).		
Estrategia	**Transferir**		
Plan de respuesta	1. Renegociar el contrato con el procesador con nivel de servicio (SLA) y penalizaciones. 2. Contratar una póliza de seguro por interrupción de negocio. 3. Segundo enlace de comunicaciones con otro proveedor. 4. Procedimiento manual de contingencia en caja con formatos y límites.		
Responsable	Director de TI	**Tiempos**	Contrato y enlace en 60 días; póliza en 90 días; prueba de contingencia semestral.
Recursos	Área jurídica, compras, presupuesto para el segundo enlace y la póliza.		

R9 Acceso privilegiado indebido — Alto

Activo afectado	Cuentas de administrador de servidores, bases de datos y sistema de gestión de casino.		
Amenaza	Empleado, exempleado o proveedor con acceso remoto que usa privilegios para modificar saldos, datos o borrar registros.		
Vulnerabilidad	Cuentas de administrador compartidas, bajas de personal sin retirar accesos a tiempo y sin registro de sesiones privilegiadas.		
Fuente	Interna	**Categoría**	Tecnológico
Probabilidad / Impacto	Media / Alto	**Nivel**	**Alto**
Justificación	La revisión de accesos se hace una vez al año y existen cuentas genéricas (Media). Un abuso puede alterar saldos, borrar evidencia y facilitar fraudes (Alto).		
Estrategia	**Mitigar**		
Plan de respuesta	1. Eliminar cuentas compartidas y asignar cuentas nominales. 2. Herramienta de gestión de accesos privilegiados (PAM) con grabación de sesiones. 3. Retiro de accesos el mismo día de la baja, ligado al aviso de Recursos Humanos. 4. Revisión trimestral de accesos por cada dueño de sistema, con mínimo privilegio.		
Responsable	Jefe de Seguridad de la Información (CISO)	**Tiempos**	Cuentas nominales en 30 días; PAM en 120 días; revisión trimestral.
Recursos	Licencia PAM, Recursos Humanos, dueños de sistema.		

R10 Fuga de datos de clientes — Alto

Activo afectado	Base de datos de clientes: identificaciones, contacto, historial de juego y datos bancarios.		
Amenaza	Robo de información por un atacante externo que la vende o la usa para fraudes.		
Vulnerabilidad	Datos personales sin cifrar en reportes y respaldos, exportaciones a hojas de cálculo sin control y sin herramienta de prevención de fugas.		
Fuente	Externa	**Categoría**	Reputacional
Probabilidad / Impacto	Media / Alto	**Nivel**	**Alto**
Justificación	La base de clientes es valiosa para fraudes y circula en reportes internos (Media). Una fuga afecta la confianza de clientes frecuentes y VIP y puede derivar en sanciones conforme a la LFPDPPP (Alto).		
Estrategia	**Mitigar**		
Plan de respuesta	1. Clasificar y cifrar los datos personales en bases de datos y respaldos. 2. Enmascarar datos en reportes y bloquear exportaciones masivas. 3. Herramienta de prevención de fuga de datos (DLP) en correo y USB. 4. Procedimiento de atención a vulneraciones y capacitación anual en protección de datos.		
Responsable	Oficial de Privacidad	**Tiempos**	Cifrado en 90 días; DLP en 120 días; capacitación anual.
Recursos	Apoyo del CISO y del equipo de bases de datos, licencia DLP, asesoría legal.		

R11 Falla de respaldos — Alto

Activo afectado	Respaldos de bases de datos, servidores y video.		
Amenaza	Respaldos incompletos, dañados o cifrados junto con los sistemas durante un ataque.		
Vulnerabilidad	No se prueban restauraciones, los respaldos están en la misma red que producción y no hay copia fuera de sitio inmutable.		
Fuente	Interna	**Categoría**	Tecnológico
Probabilidad / Impacto	Alta / Medio	**Nivel**	**Alto**
Justificación	Sin pruebas de restauración es muy probable que algún respaldo no funcione cuando se necesite (Alta). El daño directo es Medio porque los sistemas siguen operando, pero se agrava si coincide con R7.		
Estrategia	**Mitigar**		
Plan de respuesta	1. Regla 3-2-1: tres copias, en dos medios distintos, una fuera de sitio e inmutable. 2. Prueba mensual de restauración de los sistemas críticos. 3. Monitoreo diario de los trabajos de respaldo con alerta por falla. 4. Definir tiempo objetivo de recuperación (RTO) y pérdida máxima de datos (RPO) por sistema.		
Responsable	Jefe de Infraestructura y Redes	**Tiempos**	RTO/RPO en 30 días; copia inmutable en 60 días; pruebas mensuales.
Recursos	Almacenamiento inmutable o en la nube, software de respaldo, operador de TI.		

R12 Uso de software no autorizado y memorias USB

Moderado

Activo afectado	Equipos de caja, estaciones de vigilancia y equipos administrativos.		
Amenaza	Instalación de programas no autorizados o conexión de memorias USB que introducen software malicioso.		
Vulnerabilidad	Usuarios con permisos de administrador en su equipo y puertos USB habilitados.		
Fuente	Interna	**Categoría**	Tecnológico
Probabilidad / Impacto	Media / Medio	**Nivel**	**Moderado**
Justificación	El personal lo hace para pasar archivos o entretenerse en turnos largos (Media). Puede introducir software malicioso y abrir la puerta a R7 o R10 (Medio).		
Estrategia	**Evitar**		
Plan de respuesta	1. Bloquear puertos USB por política, con excepciones aprobadas. 2. Retirar permisos de administrador local a los usuarios. 3. Lista blanca de aplicaciones en equipos de caja y vigilancia. 4. Política firmada por el personal y un medio aprobado para transferir archivos.		
Responsable	Jefe de Soporte Técnico	**Tiempos**	Bloqueo de USB en 30 días; lista blanca en 60 días.
Recursos	Directorio Activo, herramienta de control de aplicaciones, Recursos Humanos.		

5. Mapa de calor

El mapa cruza la probabilidad (eje vertical) con el impacto (eje horizontal). El color de cada celda corresponde al nivel de riesgo según la regla de la sección 3.4, y dentro de cada celda aparecen los ID de los riesgos que caen ahí.

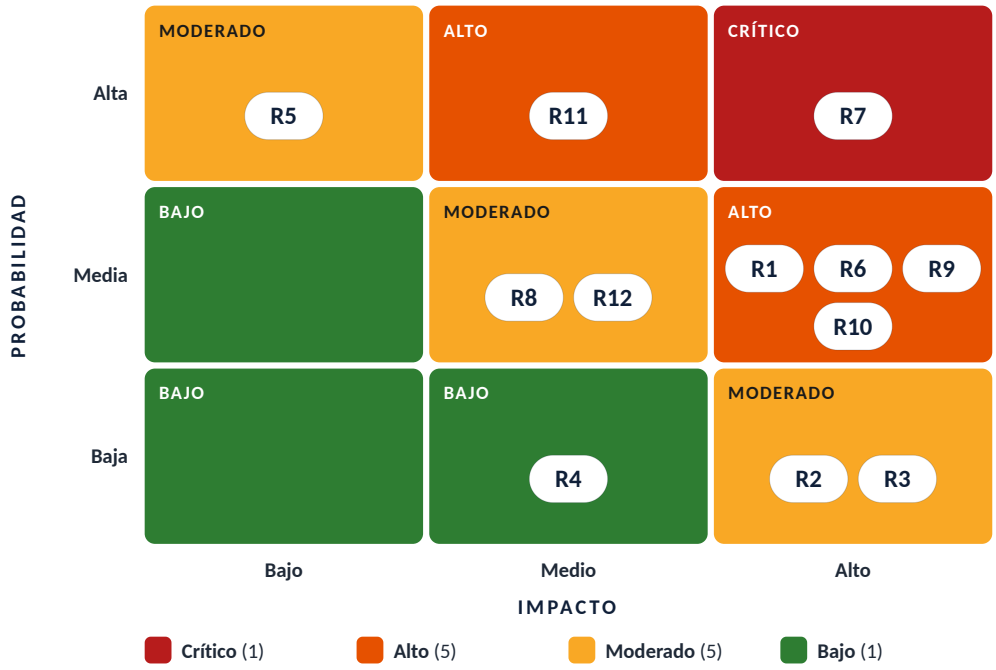


Figura 2. Mapa de calor de los 12 riesgos de Casino Royale Enterprises.

5.1 Lectura del mapa

- **Crítico:** R7 (ataque de ransomware). Es la prioridad número uno; sus acciones arrancan en los primeros 30 días y se revisa cada semana.
- **Alto:** R1 (manipulación de elementos de juego); R6 (uso del casino para operaciones con recursos ilícitos); R9 (acceso privilegiado indebido); R10 (fuga de datos de clientes); R11 (falla de respaldos). Requieren planes de respuesta en un plazo de 30 a 120 días y revisión quincenal.
- **Moderado:** R2 (colusión empleado-cliente); R3 (intervención en tragamonedas con dispositivos especializados); R5 (punto ciego o falla temporal en la vigilancia de la sala principal); R8 (caída del sistema de pagos); R12 (uso de software no autorizado y memorias USB). Se atienden con controles de costo razonable y revisión mensual.
- **Bajo:** R4 (ataque al sistema central de gestión de clientes). Se acepta con los controles actuales y se revisa cada trimestre.

Siete de los doce riesgos están en la columna de impacto Alto: si ocurren, afectan de forma directa el dinero, la ley o la confianza de los clientes. Por eso el plan da prioridad a controles preventivos. También hay riesgos que se encadenan: una falla de respaldos (R11) convierte un ransomware (R7) en una interrupción larga, y el uso de USB (R12) puede ser la puerta de entrada de R7 y R10. La meta del primer año es pasar de 6 a 3 riesgos en nivel Crítico o Alto.

6. Monitoreo y control

6.1 Objetivos

- Asegurar que los riesgos se gestionen eficazmente a lo largo del tiempo.
- Detectar cambios en los riesgos existentes o la aparición de riesgos nuevos.
- Evaluar si las medidas de tratamiento están funcionando y corregirlas a tiempo.

6.2 Qué se monitorea

- **Riesgos existentes:** si su probabilidad o impacto cambió y si se mueven en el mapa de calor.
- **Eficacia de los controles:** con los KPI de cada riesgo.
- **Nivel de exposición:** con los KRI y sus umbrales.
- **Avance de los planes de respuesta:** acciones terminadas contra lo comprometido.
- **Riesgos nuevos:** por sistemas o proveedores nuevos, cambios de ley o amenazas recientes.
- **Incidentes y casi incidentes:** registrados en la bitácora única.
- **Riesgos aceptados:** que R4 siga siendo Bajo.

6.3 Herramientas y técnicas de monitoreo

Matriz de seguimiento	Archivo de Excel con los 12 riesgos, su nivel, estrategia, responsable y avance.
Indicadores de riesgo	Tablero de KPI y KRI con semáforo: verde si el KPI cumple la meta y el KRI está bajo el umbral; amarillo si uno falla; rojo si fallan los dos.
Alertas de sistemas	Alertas del SIEM, del antimalware avanzado (EDR), de pérdida de señal de cámaras, de reglas de caja y del módulo PLD.
Reuniones periódicas	Revisiones de dueños de riesgo y del Comité de Riesgos según la frecuencia de la sección 6.5.
Auditorías	Auditoría Interna revisa cada semestre una muestra de controles; auditoría PLD independiente cada año.
Pruebas y simulacros	Simulacros de phishing, pruebas de restauración de respaldos y prueba de contingencia de pagos.
Registro de incidentes	Bitácora única para TI, vigilancia, caja y juego, base para recalcular probabilidades.

6.4 Tablero de KPI y KRI por riesgo

Los riesgos R1, R2 y R5 se retoman de la actividad de KPI y KRI del 18 de octubre de 2026. Se corrigió el KRI de R1 (“# de inconsistencias”) y en R2 se usa el término “cajeros” tanto en el control como en el KPI. Los demás riesgos tienen indicadores nuevos.

ID	Riesgo	Control	KPI (desempeño del control)	KRI (nivel del riesgo)	Interpretación	Acción
R1 **Alto**	**Manipulación de elementos de juego**	Inspección periódica de barajas y dados.	% de cartas y dados inspeccionados según protocolo semanal **Meta: ≥ 98 %**	# de inconsistencias, alteraciones o cartas defectuosas detectadas **Umbral: > 3 al mes**	Si el KPI baja y el KRI sube, las inspecciones no se realizan correctamente y aumenta el riesgo de fraude.	Auditar al personal, sancionar omisiones del protocolo y revisar los elementos de juego.
R2 **Moderado**	**Colusión empleado-cliente**	Rotación obligatoria de cajeros. Monitoreo de patrones de pago.	% de cumplimiento en la rotación programada de cajeros **Meta: 100 %**	# de transacciones sospechosas o discrepancias reportadas **Umbral: > 2 al mes**	Si el KPI es alto y el KRI sube, el esquema de rotación no es suficiente o se están omitiendo las alertas.	Iniciar investigaciones internas, auditar relaciones de personal y ajustar límites de pagos.
R3 **Moderado**	**Intervención en tragamonedas con dispositivos especializados**	Firmware actualizado, sensores de apertura y monitoreo de la red de tragamonedas.	% de máquinas con firmware vigente y sellos íntegros en la inspección mensual **Meta: ≥ 95 %**	# de eventos anómalos (aperturas no programadas, créditos o pagos fuera de patrón) **Umbral: > 1 al mes**	Si el KPI baja y el KRI sube, hay máquinas expuestas y posibles intentos de manipulación.	Retirar de servicio las máquinas afectadas, revisar el video y escalar con el fabricante.
R4 **Bajo**	**Ataque al sistema central de gestión de clientes**	Firewall de aplicaciones web, parches mensuales y escaneo trimestral.	% de vulnerabilidades críticas del CRM corregidas en 30 días o menos **Meta: ≥ 95 %**	# de alertas de alta severidad sobre el CRM al mes **Umbral: +50 % sobre el promedio**	Si el KRI sube con el KPI estable, aumentó la presión de atacantes; si ambos empeoran, el riesgo aceptado ya no es bajo.	Reevaluar la aceptación del riesgo y reforzar controles, por ejemplo con pruebas de penetración.
R5 **Moderado**	**Punto ciego o falla temporal en la vigilancia de la sala principal**	Mantenimiento preventivo y monitoreo en tiempo real del sistema de grabación.	% de disponibilidad operativa continua del sistema de cámaras **Meta: ≥ 99.5 %**	# de fallas técnicas, puntos ciegos o pérdidas de señal registradas **Umbral: > 4 al mes**	Si el KPI empeora y el KRI aumenta, existe alta probabilidad de quedar vulnerables ante robos o disputas.	Revisar la infraestructura del sistema y colocar vigilancia física temporal.
R6 **Alto**	**Uso del casino para operaciones con recursos ilícitos**	Identificación de clientes y alertas del módulo PLD.	% de operaciones sujetas a identificación con expediente completo **Meta: 100 %**	# de avisos presentados fuera de plazo y de operaciones inusuales sin revisar **Umbral: ≥ 1**	Si el KPI baja se atienden operaciones sin identificar; si hay avisos tardíos, la exposición a sanciones es directa.	Bloquear operaciones sin expediente, reforzar la capacitación y revisar el módulo PLD.
R7 **Crítico**	**Ataque de ransomware**	EDR, doble factor, parches críticos y simulacros de phishing.	% de equipos con EDR activo y parches críticos al día **Meta: ≥ 98 %**	% de empleados que caen en el simulacro de phishing **Umbral: > 5 %**	Si el KPI baja y el KRI sube, crece la superficie de ataque y el personal es más vulnerable al engaño.	Aislar equipos sin protección, dar capacitación focalizada y revisar el plan de respuesta a incidentes.

ID	Riesgo	Control	KPI (desempeño del control)	KRI (nivel del riesgo)	Interpretación	Acción
R8 Moderado	**Caída del sistema de pagos**	SLA con el procesador, póliza de interrupción y enlace alterno.	% de disponibilidad del servicio de pagos contra el SLA contratado **Meta: ≥ 99.9 %**	# de caídas del sistema de pagos y minutos sin servicio al mes **Umbral: > 2 caídas o > 60 min**	Si el KRI sube aunque se cumpla el SLA, el contrato no cubre la necesidad real del casino.	Aplicar penalizaciones, activar el enlace alterno y renegociar o cambiar de proveedor.
R9 Alto	**Acceso privilegiado indebido**	Cuentas nominales, gestión de accesos privilegiados (PAM) y revisión trimestral.	% de accesos de personal dado de baja retirados el mismo día **Meta: 100 %**	# de cuentas privilegiadas genéricas o sin dueño **Umbral: > 0**	Si el KPI baja y el KRI sube, hay privilegios sin dueño que pueden usarse para fraudes.	Deshabilitar las cuentas, revisar grabaciones de sesiones y escalar a Auditoría Interna.
R10 Alto	**Fuga de datos de clientes**	Cifrado, enmascaramiento de datos y prevención de fugas (DLP).	% de bases de datos y respaldos con datos personales cifrados **Meta: 100 %**	# de envíos o copias de datos personales bloqueados por DLP al mes **Umbral: > 5 al mes**	Si el KRI sube, hay personal sacando datos fuera del flujo autorizado; si el KPI baja, una fuga causaría más daño.	Investigar a los usuarios involucrados, reforzar la capacitación y ajustar las reglas DLP.
R11 Alto	**Falla de respaldos**	Regla 3-2-1 y pruebas mensuales de restauración.	% de pruebas de restauración exitosas en sistemas críticos **Meta: 100 %**	# de trabajos de respaldo fallidos o incompletos por semana **Umbral: > 2 por semana**	Si el KPI baja, no hay garantía de recuperar los sistemas ante un ataque como R7.	Corregir los trabajos fallidos en 24 horas, repetir la prueba y escalar al Director de TI.
R12 Moderado	**Uso de software no autorizado y memorias USB**	Bloqueo de USB, sin administrador local y lista blanca de aplicaciones.	% de equipos con USB bloqueado y sin administrador local **Meta: 100 %**	# de intentos bloqueados de instalar software o conectar USB al mes **Umbral: Aumento 2 meses seguidos**	Si el KRI sube, la práctica continúa y los usuarios están intentando saltar el control.	Hablar con los jefes de área, reforzar la política y aplicar el reglamento interno.

6.5 Frecuencia de monitoreo por nivel de riesgo

Nivel	Frecuencia	Riesgos	Cómo se revisa
Crítico	**Semanal**	R7	Reunión semanal del CISO y el Director de TI; alertas de seguridad revisadas a diario.
Alto	**Quincenal**	R1, R6, R9, R10, R11	Revisión quincenal del dueño de riesgo con el equipo de gestión de riesgos.
Moderado	**Mensual**	R2, R3, R5, R8, R12	Revisión mensual en el Comité de Riesgos.
Bajo	**Trimestral**	R4	Revisión trimestral para confirmar que la aceptación sigue siendo válida.

Además, la matriz completa se revisa cada trimestre y el marco de gestión de riesgos cada año.

6.6 Documentación y reporte

- **Matriz de riesgos** en Excel con control de versiones; cada cambio de nivel queda registrado con fecha y motivo.
- **Ficha de seguimiento** por riesgo con evidencia de las acciones terminadas.
- **Bitácora de incidentes** con fecha, causa, impacto y acciones.
- **Actas del Comité de Riesgos** con acuerdos y responsables.
- **Reporte mensual** al Comité: mapa de calor, riesgos que cambiaron de nivel, semáforo de KPI y KRI y acciones vencidas.
- **Informe trimestral** a la Dirección General con el resumen ejecutivo y las decisiones requeridas.
- Las evidencias se conservan según la política de retención de la empresa y los plazos legales aplicables.

6.7 Beneficios del monitoreo y control

- Permite responder rápido ante incidentes porque las alertas llegan a un responsable definido.
- Muestra con datos si una inversión en controles está funcionando.
- Detecta riesgos nuevos antes de que se conviertan en pérdidas.
- Da evidencia ante auditorías y autoridades.
- Ayuda a decidir dónde invertir primero.

7. Comunicación

7.1 Qué se comunica

- Riesgos identificados, su nivel y su responsable.
- Cambios de nivel y aparición de riesgos nuevos.
- Avance de los planes de respuesta y valores de KPI y KRI.
- Incidentes, sus causas y lecciones aprendidas.
- Recomendaciones y decisiones que debe tomar la dirección.
- Buenas prácticas para todo el personal (por ejemplo, cómo reconocer un correo de phishing).

7.2 Quién comunica y quién recibe

Los **responsables de riesgos** (dueños de cada riesgo, como el CISO, el Gerente de Caja y Tesorería o el Jefe de Vigilancia) informan el estado de su riesgo. El **equipo de gestión de riesgos**, encabezado por el Gerente de Riesgos y Cumplimiento, reúne la información y la difunde al Comité, a la dirección y al personal.

Quién comunica	Quién recibe	Qué	Canal	Frecuencia
Dueños de riesgo	Equipo de gestión de riesgos	Avance de planes de respuesta y valores de KPI y KRI.	Tablero compartido y correo	Según el nivel: semanal, quincenal, mensual o trimestral
Equipo de gestión de riesgos	Comité de Riesgos	Mapa de calor actualizado, riesgos nuevos o que cambiaron de nivel y recomendaciones.	Reunión y reporte ejecutivo	Mensual
Comité de Riesgos	Dirección General y accionistas	Estado general de los riesgos, inversiones y decisiones requeridas.	Informe ejecutivo	Trimestral
CISO	Todo el personal	Alertas de seguridad, intentos de phishing y buenas prácticas.	Correo, chat corporativo y pantallas en comedor	Cuando ocurra y boletín mensual
Equipo de respuesta a incidentes	Dirección General, Jurídico y Comunicación	Incidentes graves y su avance.	Llamada y grupo de crisis	Inmediato (menos de 1 hora)
Oficial de Cumplimiento PLD	Autoridad competente	Avisos de operaciones obligatorias.	Portal oficial de la autoridad	Según plazos legales
Oficial de Privacidad y Comunicación Corporativa	Clientes afectados	Vulneraciones de datos personales y medidas tomadas.	Correo y comunicado	Cuando aplique
Auditoría Interna	Comité de Riesgos	Resultados de auditorías de controles.	Informe de auditoría	Semestral

7.3 Canales de comunicación

Chat corporativo (canal de riesgos)	Avisos rápidos entre el equipo de riesgos y los dueños.
Correo electrónico	Reportes formales y evidencias.
Reuniones del Comité	Decisiones, priorización y aprobaciones.
Tablero de indicadores	KPI, KRI y mapa de calor siempre actualizados.
Intranet y pantallas internas	Campañas de concientización para todo el personal.
Pláticas de inicio de turno	Mensajes clave para cajeros, crupieres y vigilancia.
Grupo de crisis	Coordinación durante incidentes graves.

7.4 Frecuencia de comunicación

- **Inmediata:** incidentes graves o riesgos que pasan a nivel Crítico (menos de 1 hora).
- **Semanal:** seguimiento de riesgos críticos.
- **Quincenal:** seguimiento de riesgos altos.
- **Mensual:** Comité de Riesgos, riesgos moderados y boletín de seguridad al personal.
- **Trimestral:** informe a la Dirección General y revisión de riesgos bajos.
- **Anual:** revisión del plan completo y capacitación general.

8. Conclusión

Para Casino Royale Enterprises la tecnología sostiene el negocio: sin sistemas no hay caja, sin cámaras no hay control de la sala y sin datos confiables no hay programa de lealtad ni cumplimiento ante la autoridad. El plan identificó 12 riesgos, de los cuales uno es Crítico (ransomware) y cinco son Altos. Todos tienen un responsable, una estrategia, acciones con plazo y un par de indicadores para saber si el control funciona.

Importancia de la mejora continua. Los riesgos cambian: aparecen nuevas formas de ataque, se cambian sistemas y proveedores, y las leyes se reforman. Por eso el plan no termina con la matriz. El ciclo de ISO 31000 obliga a medir, revisar y ajustar: la matriz se actualiza cada trimestre, los indicadores según el nivel de cada riesgo y el marco completo cada año. Cada incidente debe dejar una lección y un ajuste en los controles.

Cultura organizacional orientada a la gestión de riesgos. Los controles técnicos no bastan si el personal no los aplica. Un cajero que rota de ventanilla, un crupier que registra la inspección de la baraja o un empleado que reporta un correo sospechoso reducen el riesgo tanto como una herramienta de seguridad. La dirección debe dar el ejemplo, reconocer a quien reporta y tratar los errores como oportunidades de mejora, no como motivo de castigo. Con esa cultura, la gestión de riesgos deja de ser un documento y se vuelve parte del trabajo diario del casino.

Referencias

Cámara de Diputados del H. Congreso de la Unión. (1947). *Ley Federal de Juegos y Sorteos*. Diario Oficial de la Federación, 31 de diciembre de 1947. https://www.diputados.gob.mx/LeyesBiblio/pdf/109.pdf

Cámara de Diputados del H. Congreso de la Unión. (2025a). *Ley Federal de Protección de Datos Personales en Posesión de los Particulares*. Diario Oficial de la Federación, 20 de marzo de 2025. https://www.diputados.gob.mx/LeyesBiblio/pdf/LFPDPPP.pdf

Cámara de Diputados del H. Congreso de la Unión. (2025b). *Ley Federal para la Prevención e Identificación de Operaciones con Recursos de Procedencia Ilícita* (Publicada en el Diario Oficial de la Federación el 17 de octubre de 2012; última reforma del 16 de julio de 2025). https://www.diputados.gob.mx/LeyesBiblio/ref/lfpiorpi.htm

International Electrotechnical Commission. (2019). *Risk management — Risk assessment techniques* (IEC 31010:2019).

International Organization for Standardization. (2018). *Risk management — Guidelines* (ISO 31000:2018). https://www.iso.org/standard/65694.html

Secretaría de Gobernación. (2004). *Reglamento de la Ley Federal de Juegos y Sorteos*. Diario Oficial de la Federación, 17 de septiembre de 2004 (última reforma del 16 de noviembre de 2023). https://www.ordenjuridico.gob.mx/Documentos/Federal/html/wo88470.html